

Playas y Ventajas — Relatório de Funcionalidades

Mapeado diretamente do código (rotas do App Router, endpoints do Worker, RPCs do banco).

Data: 29/09/2026.

1. Panorama e arquitetura

Camada	Tecnologia
Front (5 rotas, App Router)	Next.js 14 + React, i18n PT/EN/ES, tema próprio
Servidor	Cloudflare Pages — Worker em modo avançado, bundle self-contained (<code>_worker.js</code> , 273,7 kB)
API	handlers em <code>netlify/functions</code> (CJS, canon) com espelhos ESM (<code>functions/.netlify/functions</code>), 19 endpoints reais
Banco	Supabase (Postgres), regras de negócio em RPC, Storage de imagens/documentos, RLS ativa
Comunicação	WhatsApp (<code>wa.me</code>), QR code (<code>qrcodejs</code>), mapa Leaflet + OpenStreetMap/Overpass

2. Papéis do sistema

- Cliente** — identifica-se pelo telefone e resgata ofertas.
- Empresa** — estabelecimento que cria campanhas/cupons, aprova motoristas e valida cupons.
- Motorista** — parceiro que se cadastra, envia documentos e fica na frota.
- Admin** — operador da plataforma (gestão de negócios, clientes, planos, destaques).

3. Módulo Cliente (`/cliente`)

- Identificação por telefone** (`identify`): devolve `customerId` + token assinado (HMAC) anti-IDOR. Nome, Instagram e email são opcionais; **email não é mais verificado** (decisão registrada).
- Vitrine de ofertas** (`offers`): lista ativas por cidade, categoria e raio/distância (geolocalização), com imagens compensadas do catálogo.
- Mapa de proximidade**: radar (`find_nearby_businesses`) + camada de dados abertos OSM via `map-places` (Overpass, servidor-side por CORS).
- Resgate de cupom** (`claim-coupon`): caminho crítico roda RPC `claim_coupon` (estoque, hash, limite); extras best-effort: conversão de indicação (`try_referral_convert`) e link WhatsApp montado a partir do contexto do banco (nunca do navegador). Retorna QR code.
- Meus cupons** (`offers?mode=my-coupons`): exige token de cliente válido; status de resgate.
- Validação manual** (`validate-coupon`): código curto digitado, com códigos de recusa e idempotência.

4. Módulo Empresa (`/empresa`)

- Cadastro/login**: código interno + senha (PIN hashado, logout por tentativas); sem email/OTP desde a remoção de 2026-09-28.
- Painel** (empresa): relatório do negócio, dados próprios (`business_get_own/business_update_own`), telefone e logo.
- Campanhas e cupons**: cria campanha (`create_campaign`) e modelos de cupom (`create_coupon_template`), habilita/desabilita, atualiza e apaga — com benefício, estoque, imagem, modo "passeio" e proximidade.
- Gestão de motoristas**: convite (código `business-driver-invite`), lista de cadastros/detalhes, análise de documentos (`driver-review-document`), abertura do arquivo por **URL assinada de 5 min** (`driver-document-url`, storage privado), aprovação/recusa/suspensão.
- Validação de cupom** na tela e **troca de PIN** (`business_set_pin`).
- Upload de imagem** (`upload-image`): valida base64, MIME e tamanho; storage com path montado no servidor.

5. Módulo Motorista (`/motorista`)

Fluxo completo com lógica pura testada em `app/motorista/logic.js`:

- Cadastro** (`driver-register`): com código de convite da empresa; devolve `uploadToken/pinToken`.
- Definir PIN** (`driver-set-pin`): `pinToken` é descartável (uma vez); `uploadToken` segue valendo para o documento.
- Login** (`driver-login`): telefone + PIN, com logout; emite sessão mesmo para `pending/rejected` (acesso ao app, não à frota); `suspended` → 403.
- Documentos** (`driver-add-document`): upload de CNH/RG/CRV para storage privado, validação de MIME/conteúdo e limite de 6 MB; recusa exige novo envio.
- Situação**: `pending / approved / rejected / suspended`; só `approved` dirige (`canDrive`) e só `approved` aparece em `list_live_vehicles` (módulo 1).
- Sessão e reidratação**: token de sessão OU token de cadastro (exatamente um por request); logout explícito.

6. Módulo Admin (/admin)

- **Login** com checagem de papel `ADMIN/SUPER_ADMIN` (não basta entrar).
- **Negócios:** listar, criar (nome, CNPJ, logo, plano, dono com código+pin), ativar/desativar, editar, apagar.
- **Planos/faturamento:** painel `admin_billing_panel`, troca de plano. **Plano por cupom** (`PER_COUPON`): admin define `billing_fee_cents` no card do negócio; a cada resgate (`claim-coupon`) a taxa é acumulada em `billing_charges` (`coupon_id` preenchido, dedupe por cupom) e vista no painel `billing` — cobrança manual, sem assinatura MP (`billing_mp_prepare` recusa `PER_COUPON` com `PLAN_NOT_SUBSCRIPTION`).
- **Destaques:** `admin_featured_ranks` / `admin_set_featured`.
- **Clientes:** busca e edição (nome, email, Instagram, ativo).
- **Rreset de senha** de negócio (PIN temporário) e **reset de PIN de motorista** (`admin_driver_reset_pin`).

7. Regras de negócio no banco (RPCs)

Grupos por domínio (56 funções com `search_path` fixado):

- **Autenticação:** `auth_login`, `register_business`, reset de senha/PIN. `auth_login_by_email` e `register_business_by_email` **removidas** (migração `drop_email_auth`).
- **Ofertas/busca:** `list_offers`, `list_offers_public`, `list_cities`, `list_customer_coupons`, `business_logo_by_id`, `find_nearby_businesses`, `set_coupon_proximity`, `featured`.
- **Cupons:** `claim_coupon`, `validate_and_redeem_coupon`, `grant_coupon_internal`.
- **Motoristas:** `driver_register/set_pin/login/logout/verify_session/add_document/review_document/list_documents/list_for_business/get_document_path`, `admin_driver_reset_pin`.
- **Empresa:** `business_get_own`, `business_update_own`, `business_report`, `business_generate_invite`, `business_logo_by_id`.
- **Admin:** gestão de negócios/faturamento/clientes/destaques/delete.
- **Faturamento fase 2:** `billing_record_coupon_tax` (taxa por resgate em `PER_COUPON`, dedupe por `coupon_id`), `billing_mp_prepare/register/cancel` e webhooks MP recusam/ignoram `PER_COUPON`.
- **Afiliação/indicação** (pronto no banco, **sem tela no front**): `affiliate_register`, `affiliate_report`, `referral_track`, `referral_convert`, `try_referral_convert`, `get_referral_bonus`.
- **Translado/proximidade** (RPCs existentes, sem UI dedicada): `list_shuttle_services`, `list_live_vehicles`.

8. Segurança (estado atual)

- Erro interno **nunca** em resposta HTTP (sanitizado em 500/409, ambos dialetos) — 2026-09-28.
- Erros de sessão são contrato 401 (`SESSION_REQUIRED` / `SESSION_EXPIRED`).
- Tokens de cliente HMAC (anti-IDOR); storage privado com URL assinada; `no-store` em rotas de sessão; CORS controlado.
- PIN hashado + lockout em memória e `login_attempts`; `search_path` fixo; `REVOKE` de `function_exec`; RLS ativa.
- Pendências registradas em **SECURITY-DECISIONS.md** (inclui vazamento de credenciais numa conversa anterior — rotação a critério do dono).
- Bateria de segurança da fase 2 (2026-09-29): apenas `service_role` executa as funções de app (regra 4 → `app_ainda_abertas=0`); `billing_record_coupon_tax` não aparece nos advisors de `SECURITY DEFINER` exposto (anon/authenticated). Único ERROR restante é `spatial_ref_sys` sem RLS — catálogo de SRIDs da extensão postgis, owned por `supabase_admin`; o `ALTER TABLE ... ENABLE ROW LEVEL SECURITY` exige ownership/superuser e falha com `42501 must be owner` tanto no MCP quanto no SQL Editor do dashboard (ambos rodam como `postgres`, não-superuser, sem membership em `supabase_admin`; grants feitos pelo `supabase_admin` — sem caminho SQL). Risco aceito e documentado em `SECURITY-DECISIONS.md` (dado de referência, sem PII; remediação exigiria intervenção do Supabase).

9. Qualidade

- **202 testes passando / 0 falhas / 6 pulados** (`node:test`) — cobrem handlers, lógica pura, consistência CJS/ESM, headers e asset routing do Worker.
- Testes **live opcionais** (smoke + aprovação de motorista) rodam com `RUN_LIVE=1` contra produção.
- Build gera Worker autocontido; rotas fora da whitelist → 404.